

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|--------------------------|-------------------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Recommendation:

Based on the control and compliance assessment, Botium Toys should prioritize the implementation of the following security measures:

1. Implement a least privilege access policy
Access to systems and sensitive information should be limited to authorized employees based on their job responsibilities. This would reduce the risk of unauthorized access to sensitive customer and business data.

2. Implement a strong password policy and password management system
Botium Toys should enforce strong password requirements and implement a secure password management solution. This would reduce the risk of compromised accounts and unauthorized access.
3. Implement regular data backups and disaster recovery procedures
Critical business and customer data should be backed up regularly and a disaster recovery plan should be established and tested. This would improve the organization's ability to recover from data loss, system failures, or security incidents.
4. Implement encryption for sensitive data
Sensitive customer information, including payment and personally identifiable information, should be encrypted when stored and transmitted. This would reduce the impact of a potential data breach.
5. Improve network security monitoring
Botium Toys should implement appropriate firewall protections and an intrusion detection system (IDS) to monitor network activity and identify suspicious behavior.
6. Strengthen compliance with PCI DSS and GDPR
Botium Toys should ensure that access to credit card and EU customer information is restricted to authorized personnel. The organization should also establish procedures for data classification, secure data handling, and breach notification.
7. Establish and document security policies
Security and privacy policies should be formally documented, communicated to employees, and regularly reviewed. This would provide a consistent framework for protecting company and customer information.
8. Regularly review and update security controls
Security controls should be periodically assessed to identify weaknesses and ensure that they remain effective as the organization's systems, threats, and business requirements evolve.

Priority

The highest priority should be given to access control, password security, data protection, backups and disaster recovery, and compliance with PCI DSS and GDPR. These measures would reduce the risk of unauthorized access, data breaches, data loss, and regulatory non-compliance while improving Botium Toys' overall security posture.